

Module 9 Assignment:

Designing an Enterprise Identity & Access Framework

JR Clark (002035589)

NEU DAMG7350 (Spring 2026)

Identity and Access Management Framework for a Fintech Startup

The organization's current authentication and authorization model relies heavily on passwords, standing administrative access, and inconsistent controls across SaaS platforms. This creates material risk for a fintech environment handling PCI and GDPR-regulated data. The proposed Identity and Access Management (IAM) framework establishes a unified, standards-aligned approach using Microsoft Entra ID for identity, Duo for MFA, role-based access controls, just-in-time (JIT) elevation, and a password vault with rotation. The design aligns with NIST SP 800-63B, NIST SP 800-53 Rev. 5, PCI DSS v4.0, and GDPR requirements while respecting operational constraints, engineering release cycles, and quarterly budgets. The implementation plan prioritizes the highest-risk systems first—anything touching financial data or customer PII—before expanding MFA and SSO to lower-risk applications. This sequencing reduces exposure quickly without disrupting customer transactions or ongoing product development. The result is a defensible IAM program that improves security posture, supports business agility, and meets regulatory expectations.

Authentication Strategy

Centralized Identity and MFA: Microsoft Entra ID serves as the identity provider for all employees, with Duo MFA enforced through Conditional Access. This creates a single authentication perimeter for AWS, Slack, GitHub, Jira, billing systems, and internal tools. Duo's integration with Conditional Access ensures MFA is required for high-risk events such as new devices, new locations, or privileged actions (Duo Security, n.d.).

Mitigating Authentication Vulnerabilities: NIST SP 800-63B identifies several vulnerabilities inherent to password-only authentication, including credential stuffing, phishing,

password reuse, and brute-force attacks (NIST, 2023). The organization currently exhibits several of these weaknesses. The framework mitigates them through:

- MFA for all regulated systems
- Risk-based authentication
- Device health checks
- Password vault with rotation
- SSO to reduce password sprawl

MFA fatigue is also addressed. Attackers increasingly rely on push-bombing to trick users into approving fraudulent requests. Duo's Verified Push and risk-based prompts reduce unnecessary MFA challenges and provide contextual information to prevent fatigue-based approvals (Fortra, n.d.).

Password Vault and Credential Rotation: A corporate password vault stores shared credentials, service accounts, and API keys. Privileged credentials rotate every 90 days, service accounts rotate automatically, and break-glass accounts rotate after each use. This aligns with PCI DSS 8.x requirements for credential lifecycle management (PCI Security Standards Council, 2022).

Authorization Strategy

Role-Based Access Control (RBAC): The authorization model follows NIST's RBAC structure, assigning permissions to roles rather than individuals (NIST, n.d.). Three primary roles—Engineering, Finance, and Customer Service—receive access strictly aligned to job function:

- Engineering: CI/CD, infrastructure, monitoring; no customer PII
- Finance: billing, reporting, financial data; no engineering systems

- Customer Service: CRM and account tools; no financial data

This enforces least privilege and data minimization, supporting both PCI DSS and GDPR.

Just-In-Time Privileged Access: Standing administrative access is eliminated.

Privileged roles require JIT elevation through Entra Privileged Identity Management (PIM), with peer approval and Duo step-up MFA. This directly aligns with NIST SP 800-53 Rev. 5 controls for:

- Dual authorization (AC-3(2))
- Separation of duties (AC-5)
- Least privilege (AC-6)
- Time-bounded access (AC-2(7))
- Privileged activity auditing (AU-6) (NIST, 2024)

Elevation windows range from 30–120 minutes depending on role and task. All elevated actions are logged and reviewed weekly or monthly depending on sensitivity.

Session Management: Session policies reflect operational needs:

- Finance and Customer Service: 1–2 hour sessions, shorter off-premise
- Engineering: 4–8 hour sessions during working hours, shorter after hours
- Duo step-up for sensitive actions
- Conditional Access evaluates risk continuously

These controls reduce exposure without disrupting workflows.

Access Reviews and Accountability: Managers conduct semi-annual access recertification and quarterly tabletop reviews. No manager can delegate responsibility for access decisions. This satisfies PCI DSS 7.x and GDPR accountability requirements.

Compliance Mapping

PCI DSS Alignment

The framework meets key PCI DSS v4.0 controls:

- MFA for administrative and CDE access (8.4.2)
- Role-based access and least privilege (7.1–7.2)
- Credential rotation and strong authentication (8.3)
- Logging of authentication and privileged actions (10.x)

SSO and JIT access reduce the risk of unauthorized access to cardholder data.

GDPR Alignment

The design supports GDPR principles:

- Data minimization through RBAC (Art. 5(1)(c))
- Access controls and accountability (Art. 24, 25, 32)
- Immediate revocation of access via centralized identity
- Audit logs supporting investigations and data subject rights

The framework ensures that only authorized personnel can access personal data and that access is fully traceable.

Business-Aligned Implementation Plan

Phase 1: Immediate Risk Reduction (0–90 Days)

This phase focuses on systems with PCI/GDPR-covered data and overdue regulatory requirements.

- Enforce Duo MFA for billing, financial systems, and PII
- Implement SSO for AWS, Slack, and CRM
- Deploy JIT access for all privileged roles

- Begin vault-managed credential rotation
- Address any missed regulatory deadlines to avoid penalties

This closes the highest-risk gaps first without disrupting customer transactions.

Phase 2: MFA and SSO Expansion (90–180 Days)

Once regulated systems are secured, MFA and SSO expand to the rest of the environment.

- Extend Duo MFA to all SaaS applications
- Expand Entra ID SSO to GitHub, Jira, Confluence, Datadog, Snowflake
- Implement RBAC across all systems
- Deploy session timeout policies by role and risk

This phase spreads cost across quarters and avoids overwhelming teams.

Phase 3: Operational Hardening (180–365 Days)

The final phase focuses on automation and long-term governance.

- Automate provisioning and deprovisioning
- Expand vault automation for service accounts and API keys
- Integrate IAM controls into SDLC and release management
- Conduct annual PCI DSS and GDPR readiness assessments

This ensures the IAM program remains sustainable and audit-ready.

Managing Operational Constraints

The plan avoids IAM changes during major product releases and ensures Engineering retains stable access during deployment windows. Customer Service workflows remain uninterrupted, and Finance avoids changes during quarter-end cycles. No system moves to the next phase until privileged access is fully controlled.

Summary

This IAM framework gives the organization a defensible, standards-aligned foundation without slowing the business down. By prioritizing the systems that handle PCI and GDPR-regulated data, the plan closes the highest-impact risks first and ensures the company meets its regulatory obligations before they become liabilities. The combination of Entra ID, Duo MFA, RBAC, JIT access, and vault-managed credentials replaces inconsistent, password-heavy practices with a unified identity perimeter grounded in NIST guidance and mapped directly to PCI DSS and GDPR requirements.

The phased implementation approach reflects how the business actually operates—respecting release cycles, quarterly budgets, and the need to avoid customer-facing disruption. It also prevents the common failure mode of half-implemented IAM programs by ensuring that privileged access, regulated data, and overdue compliance requirements are addressed before expanding MFA and SSO across the rest of the environment. As the organization grows, the framework scales with it: automated provisioning, continuous monitoring, and regular access reviews keep the environment secure without adding operational friction.

AI Use Statement

Microsoft Copilot was used to validate the structure of this IAM framework and to assist in navigating lengthy standards documentation, including NIST SP 800-63 and NIST SP 800-53 Rev. 5 (Update 1), which span several hundred pages. Copilot helped identify relevant control families and authentication-related vulnerabilities. All analysis, synthesis, and final decisions reflect my own judgment and were reviewed and edited to ensure accuracy and alignment with Northeastern University's Academic Integrity and Use of AI policy.

References

Duo Security. (n.d.). Protecting Microsoft Azure Conditional Access with Duo.

<https://duo.com/docs/azure-ca>

European Union. (2016). General Data Protection Regulation (GDPR). [https://eur-](https://eur-lex.europa.eu/eli/reg/2016/679/oj)

[lex.europa.eu/eli/reg/2016/679/oj](https://eur-lex.europa.eu/eli/reg/2016/679/oj)

Fortra. (n.d.). MFA fatigue: Understanding the risks and how to mitigate them.

<https://www.fortra.com/blog/mfa-fatigue-understanding-risks-and-how-mitigate-them>

National Institute of Standards and Technology. (n.d.). Role-Based Access Control (RBAC)

Project. <https://csrc.nist.gov/projects/role-based-access-control>

National Institute of Standards and Technology. (2023). Digital Identity Guidelines:

Authentication and Lifecycle Management (SP 800-63B), Security Considerations.

<https://pages.nist.gov/800-63-4/sp800-63b/security/>

National Institute of Standards and Technology. (2024). Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5, Update 1).

<https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>

PCI Security Standards Council. (2022). Payment Card Industry Data Security Standard: Requirements and Testing Procedures, Version 4.0.

https://www.pcisecuritystandards.org/document_library